



Full Product Specification & Build Plan

Prepared by: Oluwafemi Adebayo | University of Maryland, M.Eng. Cybersecurity | June 2026
Build Start

Confidential — Personal Working Document

Table of Contents

1	Executive Summary
2	Problem Statement
3	The Core Idea — What Breach Replay Does
4	Why This Has Not Been Done Well
5	Target Users and Buyer Personas
6	Product Features — Full Specification
7	Data Pipeline — Breach Advisory to Playable Scenario
8	Technical Architecture
9	Tech Stack
10	Build Plan — June to December 2026
11	Monetization and Pricing
12	Go-to-Market Strategy
13	Competitive Landscape
14	Your Unfair Advantage
15	Risks and Mitigations
16	Success Metrics
17	First Week Action Items

1. Executive Summary

Breach Replay is a cybersecurity incident response training platform that converts real-world breach disclosures into live, interactive simulations. Security teams experience reconstructed versions of actual attacks, make real-time decisions, and receive AI-generated gap analysis mapped to NIST IR and MITRE ATT&CK frameworks. The platform does not simulate fictional scenarios. It replays history so teams can practice stopping it.

The core insight is simple and devastating: every company that gets breached writes a post-mortem. That document sits in a folder nobody reads. The analysts who will respond to the next incident were not present for the last one. Breach Replay closes that gap by turning institutional knowledge into a training asset that the entire team can interact with.

Dimension	Detail
Product type	B2B SaaS, incident response training platform
Primary market	SOC teams, MSSPs, healthcare orgs, federal contractors
Revenue model	Monthly subscription + enterprise annual contracts
Solo buildable?	Yes. MVP in 8 weeks. Full v1 in 6 months.
Moat	Proprietary scenario library grown from public breach corpus
Build start	June 2026

2. Problem Statement

The cybersecurity training industry has a content problem. Most platforms teach defenders using fictional, sanitized scenarios built by vendors who have never managed a live incident. The result is training that feels academic and fails to prepare teams for the psychological pressure of an actual breach in progress.

Three specific failures define the current market:

- Fictional scenarios remove emotional stakes. Teams do not respond the same way to a made-up ransomware simulation as they do to knowing that the Colonial Pipeline was actually offline for 6 days after exactly this sequence of alerts.
- Institutional memory evaporates. When a company suffers a breach, the lessons live in the heads of the people who were present. Staff turnover means that knowledge disappears within 18 months. No platform currently converts post-mortem documents into replayable training assets.
- Debrief quality is low. Existing tabletop tools tell teams what they did wrong. They do not map the failure to a specific NIST IR control gap, generate a remediation checklist, or produce compliance evidence for an auditor.

The market size behind this problem

Global cybersecurity training market: \$6.7B in 2024, projected \$15.8B by 2029 (MarketsandMarkets).

Average cost of a data breach: \$4.88M in 2024 (IBM Cost of a Data Breach Report).

Mean time to identify a breach: 194 days. Mean time to contain: 64 days. Teams that train on realistic scenarios reduce both figures significantly.

HIPAA, FedRAMP, CMMC, and SOC 2 all require documented incident response training. Breach Replay produces that documentation as a byproduct of the simulation itself.

3. The Core Idea — What Breach Replay Does

Breach Replay ingests real breach disclosure documents — CISA advisories, SEC 8-K filings, HHS breach portal reports, and company post-mortems — and uses an LLM pipeline to extract the chronological alert sequence, initial access vector, lateral movement pattern, and key decision points from each incident.

These are converted into interactive simulations where a SOC team receives the same alerts, in the same order, on the same timeline compression as the original incident. Team members make decisions at each branch point. The platform scores those decisions against what actually happened, and against what NIST SP 800-61 says should happen. After the simulation ends, an AI-generated debrief report is produced automatically.

The three product moments that matter:

The alert feed

Participants see a live feed of security events exactly as a real SOC would — SIEM alerts, EDR detections, auth logs, network anomalies. Nothing is labelled as a simulation. The psychological pressure is real.

The decision gate

At key moments the simulation pauses and presents branching choices. Each choice has consequences that ripple forward. A wrong containment decision at minute 5 means the scenario gets harder at minute 20.

The debrief

After the simulation, the platform generates a full gap analysis: what your team did, what actually happened, what the framework says you should have done, and a prioritized remediation checklist specific to your org's profile.

4. Why This Has Not Been Done Well

Competitor	What They Do	What They Miss
Immersive Labs	Gamified cyber skills training	Fictional scenarios, no real breach data, no debrief gap analysis
AttackIQ	Breach and attack simulation (BAS)	Tests controls, not human decision-making; no team training angle
Cybereason	Tabletop exercise facilitation	Consultant-led, expensive, not self-serve, no real-incident corpus
SANS Cyber Ranges	Technical CTF-style ranges	Technical skill only, not IR decision-making; no compliance output
Breach Replay	Real breach replay + team IR training + compliance debrief	This gap. Nobody owns it.

5. Target Users and Buyer Personas

Primary buyer — CISO

Mid-size company (200-2000 employees). Responsible for IR readiness, compliance evidence, and board reporting. Pain: mandatory IR training requirements with no good solution that produces audit-ready documentation. Budget authority: \$50k-200k/year for security tooling. Decision timeline: 30-60 days.

Primary user — SOC Analyst (L1/L2)

The person who will actually run the simulation. Wants realistic training that builds muscle memory for real incidents. Currently trains on fictional tabletops that do not feel relevant. Becomes a product champion internally if the simulation is actually engaging.

Secondary buyer — MSSP

Managed Security Service Provider offering IR training as a service to their clients. Will white-label Breach Replay under their own brand. High volume, lower per-seat margin but large multiplier effect. 10 MSSPs each serving 50 clients = 500 paying orgs with one contract.

Secondary buyer — Healthcare Compliance Officer

HIPAA requires documented IR training. Healthcare has the highest breach rate of any sector (IBM 2024). The HHS breach portal gives us free scenario content from real hospital incidents. This buyer is actively looking for a solution and has a clear compliance mandate to satisfy.

6. Product Features — Full Specification

6.1 Scenario Library

A searchable library of playable simulations built from real breach disclosures. Each scenario includes metadata: attack type, industry vertical, MITRE ATT&CK techniques used, affected asset types, regulatory framework relevance (HIPAA, CMMC, FedRAMP, SOC 2), and estimated play time. Filters allow a healthcare SOC to find scenarios specific to their environment. New scenarios are added weekly using the automated ingestion pipeline.

- Minimum 50 scenarios at launch from public breach corpus
- MITRE ATT&CK and NIST IR tagging on every scenario
- Industry vertical filtering (healthcare, energy, finance, government)
- Difficulty rating: awareness, practitioner, expert
- Estimated completion time per scenario

6.2 Live Simulation Engine

The core product experience. Teams enter a timed simulation room. Alerts stream in on a compressed timeline (a 6-hour incident plays in 45 minutes). Each alert is rendered as it would appear in a real SIEM or EDR console — not a cartoon version of one. Decision gates pause the stream and present branching choices. Wrong decisions change the difficulty of subsequent events.

- Realistic SIEM-style alert rendering (not gamified UI)
- Compressed timeline with configurable speed multiplier
- Branching decision engine — choices have downstream consequences
- Multi-player support — up to 8 team members per session
- Role assignments: Incident Commander, Forensic Analyst, Communications Lead
- Real-time team chat inside the simulation
- Observer mode for managers to watch without participating

6.3 AI Debrief Engine

After each simulation, the platform generates a structured debrief report automatically. This is the feature CISOs will pay for independently of everything else. The report maps team decisions to NIST SP 800-61 controls, identifies specific gaps, and produces a prioritized remediation checklist. The report is exportable as a PDF suitable for audit evidence submission.

- Decision-by-decision scoring with rationale
- NIST SP 800-61 control gap analysis
- MITRE ATT&CK technique coverage heatmap
- Team performance trend over time (requires multiple sessions)
- Remediation checklist with owner assignment and due date fields
- PDF export formatted for audit submission
- Benchmark comparison: how your team performed vs others in your industry

6.4 Scenario Uploader — Private Incidents

Enterprise tier feature. An organization can upload their own post-mortem document and the platform converts it into a private, internal simulation accessible only to their team. This is the sticky enterprise feature — once a company has uploaded their own breach history, they will not leave.

- PDF and DOCX post-mortem upload
- LLM-powered extraction of timeline, alerts, and decision points
- Human review step before scenario goes live (quality control)
- Private scenario flag — never shared with other organizations
- Version history — update the scenario as the investigation matures

6.5 Compliance Dashboard

A persistent dashboard showing the organization's IR training coverage. Which frameworks have been exercised, which controls have gaps, when training was last completed, and a readiness score. This view is designed for CISOs to screenshot for board presentations.

- Framework coverage: NIST CSF, NIST IR, HIPAA, CMMC, SOC 2, FedRAMP
- Training completion tracking per team member
- Readiness score (0-100) with historical trend
- Upcoming scenario recommendations based on gap analysis

- Exportable compliance report for auditors

6.6 Slack Integration

A Slack slash command that delivers bite-sized scenario prompts to the team channel once a week. Five minutes, one decision, instant debrief. This is the bottom-of-funnel engagement loop that keeps teams active between full simulations.

- `/breach-replay weekly` — sends a scenario snippet to the channel
- Team members vote on the correct decision via Slack reaction
- Correct answer and rationale posted automatically after 24 hours
- Leaderboard updated in channel weekly

7. Data Pipeline — Breach Advisory to Playable Scenario

This pipeline is the engine behind the scenario library. It runs automatically on a weekly schedule and processes new breach disclosures from public sources into playable simulations. The entire pipeline is buildable in Python and runs on a single EC2 t3.medium instance.

Step 1 — Ingestion

Crawlers monitor the following public sources for new breach disclosures: CISA Known Exploited Vulnerabilities catalog and advisories (aa-prefixed advisories), SEC EDGAR full-text search for 8-K filings containing 'cybersecurity incident', HHS Breach Portal (healthcare sector), Verizon DBIR case study appendix, and curated RSS feeds from Krebs on Security and SANS Internet Storm Center.

Tech: Python: requests + BeautifulSoup for scraping. SEC EDGAR EFTS full-text API for 8-K search. HHS portal has a public CSV download updated monthly.

Step 2 — Extraction

Each document is passed to Claude API with a structured extraction prompt. The prompt instructs the model to extract: incident date and duration, initial access vector (credential theft, phishing, unpatched CVE, etc.), chronological event timeline with approximate timestamps, MITRE ATT&CK techniques identified, affected asset types, and key decision points where the outcome could have changed.

Tech: Claude API (claude-sonnet-4-6). Prompt uses XML output tags for structured JSON extraction. Extraction confidence score attached to each field. Fields below 0.7 confidence flagged for human review.

Step 3 — Scenario Construction

Extracted data is passed to a second LLM call that constructs the playable scenario structure: alert objects (SIEM format), decision gate objects (question + options + correct answer + rationale), timeline compression map, and debrief content skeleton.

Tech: Alert objects follow a schema: {timestamp, severity, source_system, rule_id, description, raw_log}. Decision gates follow: {trigger_timestamp, context_summary, options[], correct_index, consequence_if_wrong, rationale, nist_control_ref, mitre_technique}.

Step 4 — Quality Review

All auto-generated scenarios enter a review queue before publishing. A human reviewer (you, initially) checks: factual accuracy against source document, alert realism, decision gate quality, and appropriate difficulty rating. Review UI is a simple internal admin panel built in React.

Tech: Target: 30 minutes per scenario review. At launch cadence of 5 scenarios/week, this is 2.5 hours of weekly review time.

Step 5 — Storage and Serving

Approved scenarios are stored in PostgreSQL with JSONB columns for alert sequences and decision trees. The simulation engine queries this at runtime and streams alert objects to connected clients via WebSocket.

Tech: PostgreSQL + pgvector (for semantic search of scenario library). WebSocket server: FastAPI with websockets library. Scenario metadata indexed for full-text search.

8. Technical Architecture

The architecture is intentionally simple for a solo build. Everything runs on AWS. No microservices, no Kubernetes. A monolithic FastAPI backend with a React frontend, PostgreSQL database, and WebSocket server. Scale out only when the product proves itself commercially.

Client layer

React SPA (Vite). Hosted on S3 + CloudFront CDN. WebSocket connection to simulation server for real-time alert streaming. REST API calls for all other operations.

API layer

FastAPI (Python). Single EC2 t3.medium at launch. Handles auth, scenario CRUD, simulation session management, debrief generation, Slack webhook integration, and PDF report generation.

Simulation engine

WebSocket server (FastAPI websockets). Manages active simulation sessions. Streams alert objects to connected clients on compressed timeline. Processes decision submissions and updates session state.

LLM integration

Claude API (claude-sonnet-4-6) for: scenario extraction from breach docs, decision gate generation, debrief report synthesis, and Slack snippet generation. Wrapped in a simple retry-with-backoff client.

Data layer

PostgreSQL 16 on RDS t3.micro (free tier). JSONB for scenario alert sequences and decision trees. Standard relational tables for users, organizations, sessions, and scores. pgvector extension for semantic scenario search.

Pipeline layer

Python scripts running on EC2 via cron. Ingestion crawler, LLM extraction, scenario construction, quality queue. S3 for storing source documents and generated PDFs.

Auth

Supabase Auth (JWT). Email/password + SSO via SAML for enterprise. Organization-scoped data isolation at the API layer.

9. Tech Stack

Layer	Technology	Why
Frontend	React + Vite + Tailwind	Fast build, familiar, great WebSocket support
Backend	FastAPI (Python)	You already know Python deeply from all coursework and JobAgent
Database	PostgreSQL + pgvector	You know this from KindRide; pgvector adds semantic search free
LLM	Claude API (Sonnet)	Best at structured extraction; you have direct access
Auth	Supabase Auth	Free tier handles launch; SAML SSO for enterprise later
WebSocket	FastAPI websockets	Built into the framework, no extra service needed
Hosting	AWS EC2 + RDS + S3 + CloudFront	You have AWS CP cert; familiar environment from DevOps labs
PDF gen	ReportLab (Python)	For debrief PDF export; runs server-side
Email	SendGrid	Transactional emails, free tier sufficient at launch
Monitoring	CloudWatch + Sentry	AWS native + error tracking; free at low volume
Scraping	requests + BeautifulSoup	Standard Python, no overhead
Task queue	Celery + Redis	For async scenario generation pipeline; Redis free on ElastiCache micro

10. Build Plan — June to December 2026

This is a realistic solo build plan. It assumes 15-20 hours of build time per week alongside your M.Eng. coursework. The first pilot client is the target before spending a single dollar on marketing.

Phase	Timeline	Goal	Deliverable
Week 1-2	June	Data pipeline skeleton	Ingest 3 CISA advisories into structured JSON
Week 3-4	June	Scenario schema + DB	PostgreSQL schema live, 5 scenarios seeded
Week 5-6	July	Simulation engine MVP	Alert streaming via WebSocket, one playable scenario
Week 7-8	July	Decision gate engine	Branching choices with scoring, single-player
Week 9-10	Aug	Debrief AI engine	Claude generates gap analysis report, PDF export
Week 11-12	Aug	Auth + org model	Multi-tenant, team invites, role management
Week 13-14	Sep	Scenario library UI	Search, filter, metadata, 20 scenarios live
Week 15-16	Sep	Multiplayer sessions	Up to 8 players, role assignment, team chat
Week 17-18	Oct	Compliance dashboard	Framework coverage, readiness score, trend chart

Phase	Timeline	Goal	Deliverable
Week 19-20	Oct	First pilot client	Free 30-day pilot with UMD-connected security team
Week 21-22	Nov	Slack integration	/breach-replay slash command, weekly snippets
Week 23-24	Nov	Private uploader	Post-mortem PDF upload, enterprise pipeline
Week 25-26	Dec	Public launch	Product Hunt, security community, waitlist conversion

Critical milestone: pilot client before week 20

Do not wait until the product is perfect to show it to someone. By week 8 you have one playable scenario. That is enough to put in front of a UMD professor, a DC-area startup, or a contact from your AT&T; or TekExperts network.

A pilot client gives you: real feedback on what matters, a case study for the first sales calls, and proof that someone outside your apartment finds this valuable.

11. Monetization and Pricing

Tier	Price	Who It Is For	Key Features
Starter	\$299/mo	Small teams (1-10)	5 users, public scenario library, basic debrief report
Team	\$799/mo	Mid-size SOC (10-50)	25 users, full library, full debrief, compliance dashboard, Slack bot
Enterprise	\$3,500/mo	Large orgs, MSSPs	Unlimited users, private uploader, white-label, SSO, audit export, SLA
MSSP Partner	Custom	Resellers	Volume licensing, white-label, API access, rev-share on referred clients

Revenue projections — conservative case:

Month	Clients	MRR	ARR Run Rate
Month 6 (Dec 2026)	3 Starter + 1 Team	\$1,696	\$20,352
Month 9 (Mar 2027)	8 Starter + 3 Team	\$4,789	\$57,468
Month 12 (Jun 2027)	15 Starter + 6 Team + 1 Enterprise	\$12,279	\$147,348
Month 18 (Dec 2027)	30 + 12 + 3 Enterprise + 2 MSSP	\$34,563	\$414,756

At \$414k ARR with 47 clients and 2 MSSP partners, the product is fundable at a \$3-5M seed valuation under standard SaaS multiples. That is the point at which you hire a sales person and an additional engineer rather than raising a round.

12. Go-to-Market Strategy

Phase 1 (June-September 2026) — Warm network pilots

Your first five clients will not come from cold outreach. They will come from three sources: UMD Dingman Center for Entrepreneurship connections, your AT&T; and TekExperts professional network, and the UMD cybersecurity faculty who run research groups with government agency partnerships. Offer 60-day free pilots in exchange for testimonials and feedback calls.

Phase 2 (October-December 2026) — Community seeding

Security practitioners discover products through three channels: r/netsec and r/cybersecurity (post the scenario engine as a free tool for the community), SANS reading room (submit a short whitepaper on IR training gaps), and LinkedIn content showing real breach scenarios as educational posts. Build an email waitlist before charging anyone.

Phase 3 (January 2027 onward) — Direct MSSP outreach

The DC corridor has a high density of MSSPs serving federal agencies. A single MSSP partnership multiplies your client base without multiplying your sales effort. Target: ArmorText, Telos, ManTech, KEYW, and mid-size federal IT contractors. Your UMD student status and cybersecurity credentials open introductory meetings that would otherwise require a warm intro.

The compliance angle as a door opener

Every healthcare organization, every federal contractor, and every SOC 2 Type II certified company has a line item in their compliance program for IR training. The pitch is not 'buy our training platform.' It is 'here is your documented compliance evidence, automatically generated, for the training requirement you are already paying a consultant to satisfy.' That is a completely different conversation.

13. Competitive Landscape

The category most adjacent to Breach Replay is cyber range and tabletop exercise platforms. None of them combine real breach data, team decision-making training, and automated compliance debrief in a single self-serve product. The competitive moat is the scenario library.

Every week the pipeline runs, the library grows. A competitor starting today would need 6-12 months to build equivalent scenario depth, by which time the library is 6-12 months larger.

The second moat is private scenario data. Once an enterprise uploads their own post-mortem documents and builds private simulations from them, those simulations exist nowhere else. Switching cost approaches zero for a company with no private scenarios. It approaches high for a company with 10 proprietary simulations built from their own history.

14. Your Unfair Advantage

Deep domain knowledge

Your M.Eng. in cybersecurity at UMD, combined with your ENPM604 (ML), ENPM665 (cloud security), ENPM686 (information assurance), ENPM693 (network security), and ENPM691 (exploitation) coursework, means you understand what realistic SOC alerts actually look like. This is the hardest part of building this product to fake, and you do not have to fake it.

Professional IR context

Your AT&T; Global Network Services background gives you the operational perspective of what network-level security events look like in enterprise environments. Most founders building in this space have never worked in a real SOC. You have context they do not.

Geographic location

You are in Washington DC — the single highest concentration of federal agencies, defense contractors, and HIPAA-regulated healthcare systems in the country. Your first 10 enterprise clients may all be within driving distance.

Academic credential as trust signal

A UMD M.Eng. cybersecurity student building a security training product has automatic credibility with CISOs in the DC area. UMD has deep ties to NSA, DHS, and CISA through its Center for Cybersecurity (MC2). These are warm paths to pilots that money cannot buy.

Full-stack AI build capability

You have built a complete automated pipeline (JobAgent), a RAG system, Docker/AWS infrastructure, and FastAPI backends. You do not need to hire anyone to build the MVP. That is a 6-month advantage over a non-technical founder.

15. Risks and Mitigations

Risk: LLM extraction quality is inconsistent

Breach advisory documents vary wildly in structure. Some CISA advisories have detailed timelines. Some SEC 8-K filings say only 'unauthorized access occurred.' Low-quality source documents produce low-quality scenarios.

Mitigation: Mitigation: human review queue for every scenario before publishing. Start with the highest-quality source documents (CISA technical advisories, Verizon DBIR detailed case studies). Build a quality scoring rubric. Reject scenarios below a minimum quality threshold.

Risk: Enterprise sales cycle is slow

A CISO at a 500-person company may take 60-90 days to approve a \$799/month tool due to procurement and legal review processes.

Mitigation: Mitigation: target small and mid-size companies first (under 200 employees) where the CISO is also the decision maker and budget approval is informal. Lead with a free pilot offer – the compliance evidence the platform generates is valuable enough that companies will extend the pilot rather than ending it.

Risk: Legal sensitivity around real breach data

Using real incident details to build training scenarios could create legal exposure if a scenario misrepresents what happened or a company objects to their breach being used as training material.

Mitigation: Mitigation: use only publicly disclosed breach data. Never use non-public incident information. Add clear sourcing on every scenario (CISA Advisory AA21-131A). Consult a lawyer before launch – UMD has a law clinic that assists student startups at no cost.

Risk: Solo build burnout alongside M.Eng. coursework

Building a full product while completing a graduate program is a real workload risk. Scope creep kills solo projects.

Mitigation: Mitigation: the build plan above is sequenced by dependency, not by ambition. Weeks 1-8 produce something playable. Stop there if you need to. A single working scenario is a product. Everything after that is a better product.

16. Success Metrics

What good looks like at each milestone:

End of June 2026

- One complete scenario playable end-to-end (single player)
- Pipeline converts at least 3 CISA advisories to structured JSON
- PostgreSQL schema finalized and seeded

End of August 2026

- Five scenarios live, two with multi-player support
- Debrief report generated for every completed session
- First external person has played a simulation (not you)

End of October 2026

- 20 scenarios in library across 3 industry verticals
- One paying pilot client (even \$1 counts — it proves willingness to pay)
- Compliance dashboard showing framework coverage

End of December 2026

- Public launch completed
- 3+ paying customers at any tier
- MRR greater than \$1,500
- Scenario library at 50+ scenarios
- At least one MSSP conversation in progress

End of June 2027

- MRR greater than \$10,000
- At least one enterprise tier customer

- Private uploader feature live and used by at least 2 clients
- Net Revenue Retention greater than 100% (customers expanding, not churning)

17. First Week Action Items — June 2026

Do not read this document again until all seven of these are done.

Day 1

Register the domain `breachreplay.com` or `breachreplay.io`. Set up a GitHub repo. Create a Notion page with this spec pasted in.

Day 2

Download 5 CISA technical advisories (Colonial Pipeline, SolarWinds, Oldsmar water plant, MOVEit, Change Healthcare). Read each one fully. Annotate the timeline.

Day 3

Write the extraction prompt for Claude API. Test it against one CISA advisory. Iterate until the JSON output is clean and structured.

Day 4

Set up the PostgreSQL schema: `scenarios`, `alerts`, `decision_gates`, `sessions`, `session_decisions`. Seed it with the first extracted scenario.

Day 5

Build the FastAPI skeleton: `POST /scenarios`, `GET /scenarios/{id}`, `POST /sessions`, `WebSocket /ws/session/{id}`.

Day 6

Build the minimal React UI: scenario list view, session room with alert feed. Connect to WebSocket. Stream alerts on a timer.

Day 7

Play through your own simulation from start to finish. Fix every thing that breaks. Then show it to one person outside of your own head.

The security training market is large, compliance-driven, and emotionally underserved. Breach Replay sits at the intersection of all three. The scenario library is the moat. The debrief is the reason CISOs pay. The private uploader is the reason they never leave. Build in that order.

Document version 1.0 — prepared May 11, 2026 — Oluwafemi Adebayo